



Helix Health

GRC Portfolio Review

HIPAA-aligned risk, compliance, and vendor posture

Prepared by IfeSec | June 2026

Confidential executive summary for Helix Health leadership



IfeSec

Executive Summary

Helix Health operates a cloud-native healthcare platform processing protected health information (PHI) across AWS infrastructure, Auth0 identity services, and a growing vendor ecosystem. This portfolio summarizes the current governance, risk, and compliance posture after the first phase of GRC platform implementation.

12

identified risks

12

active policies

10

tracked vendors

4

critical controls

Key takeaways

- Risk: 4 high/very high inherent risks are now controlled down to low or very low residual levels.
- Compliance: 12 policies mapped to the NIST CSF Protect function are active and under continuous monitoring.
- TPRM: 10 vendors segmented across 5 tiers; 2 critical vendors hold BAAs and PHI access is restricted to Auth0.
- Gaps: AWS region resiliency is accepted rather than mitigated; Stripe, GitHub, Cloudflare, and Sumo Logic lack BAAs.
- Next: Continue control testing, evidence collection, and incident response tabletop exercises in Q3.

Scope and Methodology

Scope

The review covers Helix Health's production environment hosted in AWS us-east-1 and us-west-2, the patient/provider portal authenticated via Auth0, PHI processing pipelines, business associate relationships, and the policy framework governing these assets.

Framework

Controls and risks are mapped to the NIST Cybersecurity Framework (CSF) and HIPAA Security Rule. Risk scoring uses a 5x5 probability-by-impact matrix aligned with ISO 27005 practice.

Data sources

CISO Assistant CE GRC platform exports: risk register, applied controls, compliance posture, and third-party vendor inventory. Data was validated against architecture documentation and vendor contracts.

Method

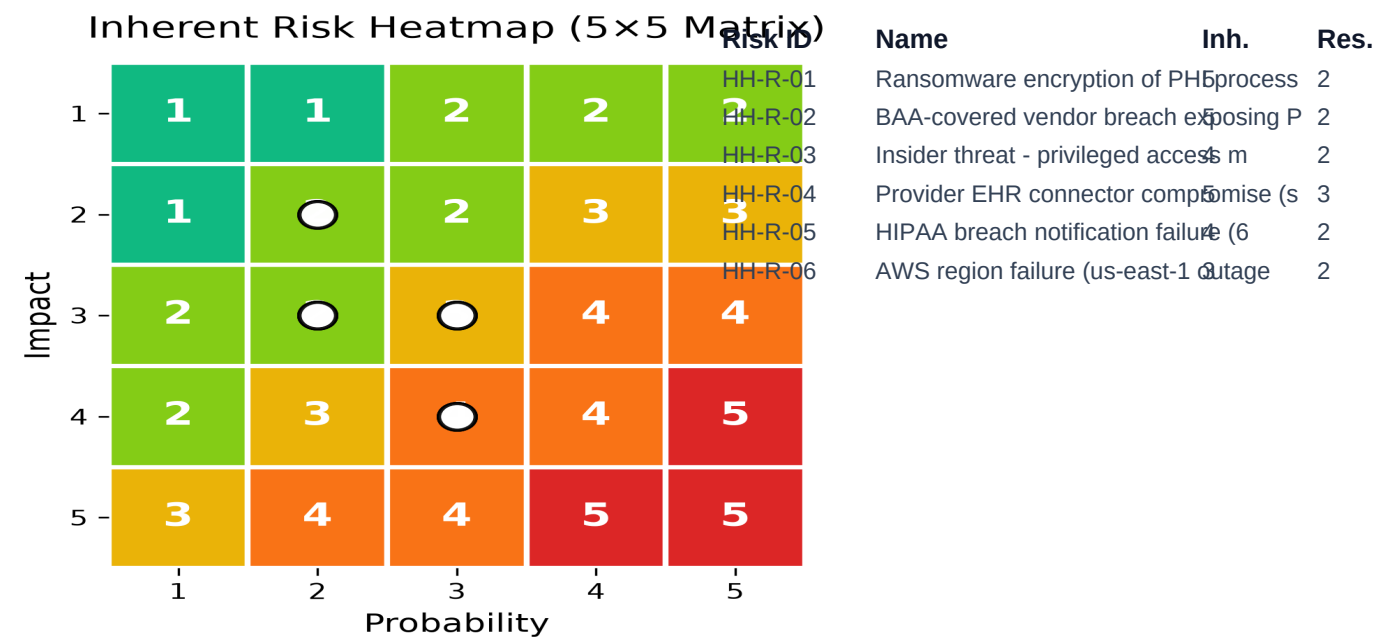
Each risk was assessed for inherent, current, and residual levels. Policies were reviewed for status, coverage, and CSF mapping. Vendors were tiered by PHI access, criticality, and BAA status.

Limitations

The assessment relies on self-reported control effectiveness and vendor attestations. Penetration testing and log-based validation are planned for Q3 to confirm control performance.

Risk Register

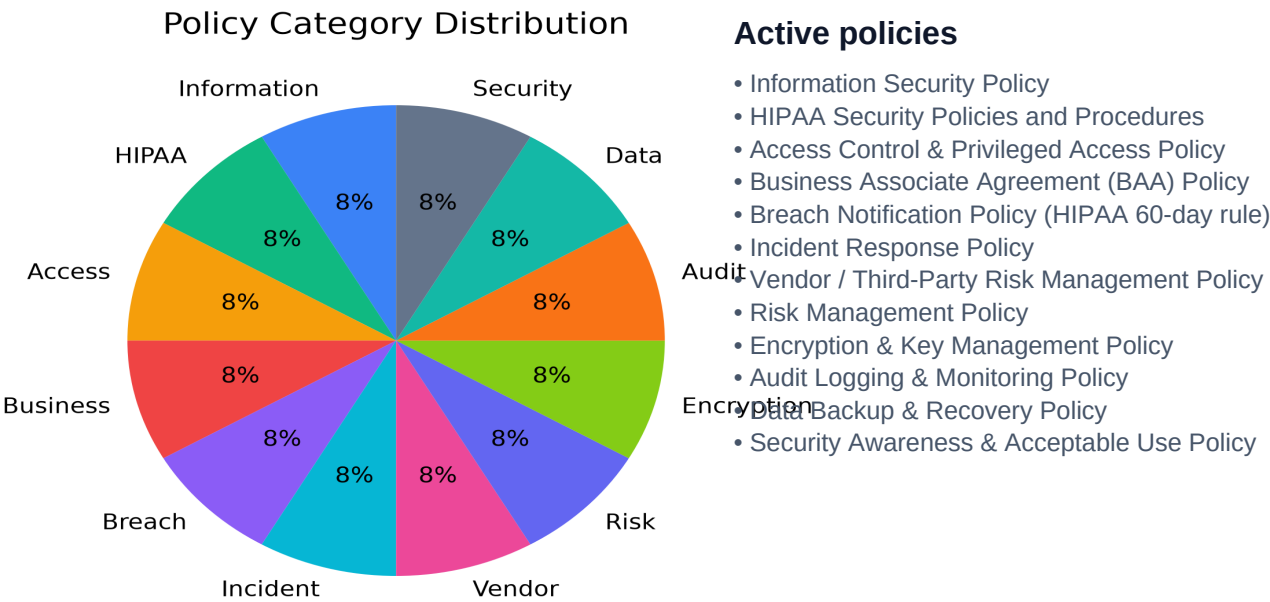
Twelve risks were assessed across inherent, current, and residual states. The heatmap plots each risk by inherent probability and impact against the 5x5 matrix.



Treatment summary: 10 mitigate, 1 accept (AWS region failure), 1 residual very low via logging controls. High inherent risks HH-R-01, HH-R-02, and HH-R-04 remain controlled to residual level 2 or below.

Policies and Controls

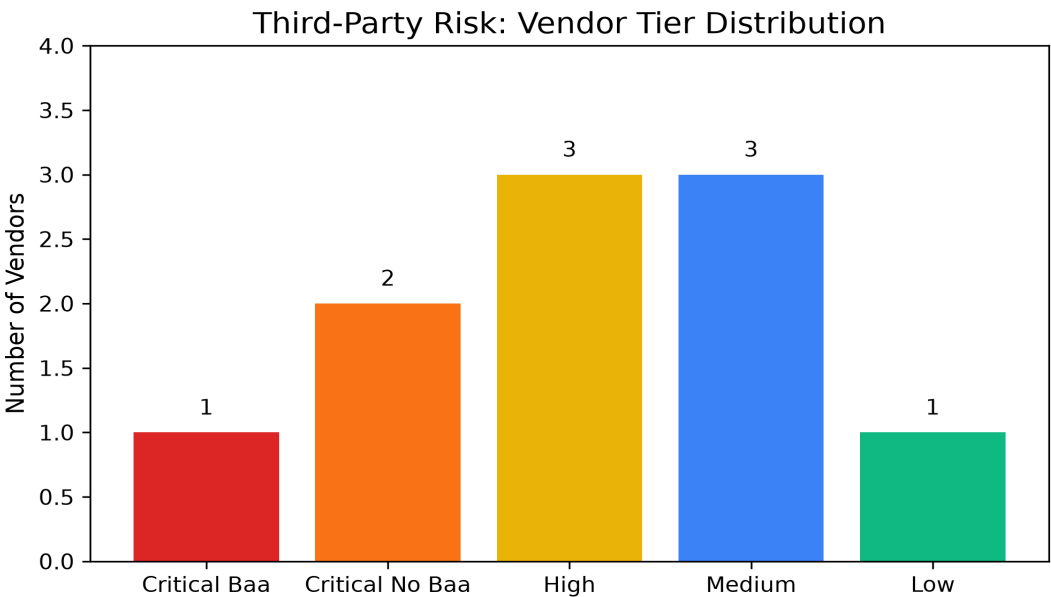
Below are the policies governing Helix Health's security and privacy program. All are active and mapped to the NIST CSF Protect function. The distribution shows coverage across access control, incident response, vendor management, encryption, and HIPAA-specific requirements.



Control maturity note: All policies are approved and published. The next phase will validate implementation effectiveness through sampling, log review, and control testing.

Third-Party Risk Management

Ten vendors support Helix Health operations. Vendors are tiered by PHI access, criticality to service delivery, and BAA coverage. Only Auth0 is classified as a critical vendor with PHI access under a BAA.

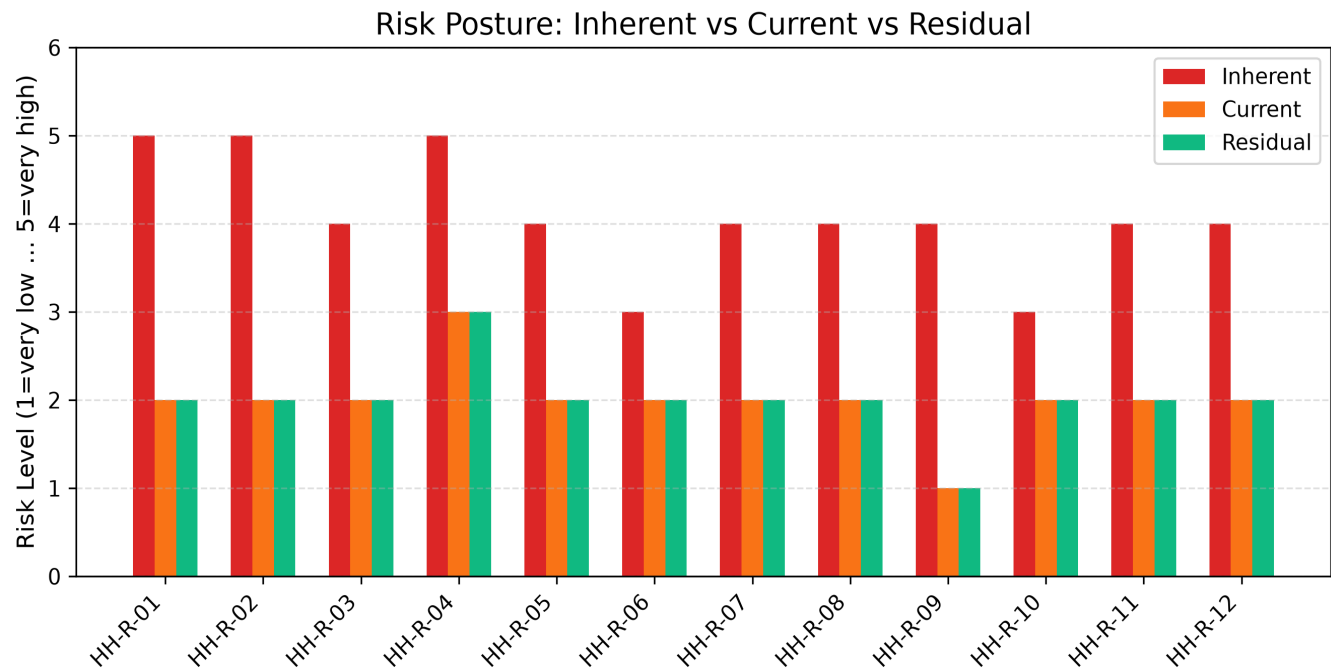


Vendor	Tier	BAA	PHI	Notes
Amazon Web Services	Critical No Baa	Yes	No	Hosting (us-east-1, us-west-2). Tier: critic...
Datadog	Critical No Baa	Yes	No	APM, log aggregation, audit log forwarding t...
Auth0 (Okta CIC)	Critical Baa	Yes	Yes	Identity provider for provider portal. Tier:...
Stripe	Low	No	No	Payment processing (subscriptions only, no P...
GitHub Enterprise	High	No	No	Source code hosting, CI/CD. Tier: high. BAA:...
Google Workspace	Medium	Yes	No	Email, docs (no PHI in Workspace). Tier: med...
PagerDuty	Medium	No	No	Incident alerting. Tier: medium. BAA: No. PH...
Cloudflare	High	No	No	WAF, DDoS protection. Tier: high. BAA: No. P...
Sumo Logic	High	No	No	Secondary log aggregation. Tier: high. BAA: ...
Vanta	Medium	Yes	No	Compliance evidence collection. Tier: medium...

Gap items: Stripe, GitHub, Cloudflare, Sumo Logic, and PagerDuty currently operate without BAAs. AWS and Datadog are critical but do not access PHI, mitigating BAA exposure. Google Workspace and Vanta have BAAs in place.

Compliance Posture

The bar chart below shows the movement from inherent risk to current and residual levels across the 12-risk register. Controls applied in Phase 1 reduced high-risk exposures to acceptable residual levels.



HIPAA Security Rule

12 policies mapped to relevant standards; breach notification policy active.

NIST CSF

All controls aligned to Protect function; Identify and Detect expansion in Q3.

Evidence collection

Vanta integration enabled for continuous control evidence collection.

Open findings

5 vendors without BAAs; 1 accepted risk (AWS region failure).

Roadmap and Next Steps

Q3 2026	Complete CISM certification track, formalize risk committee cadence, and run incident response tabletop.
Q3 2026	Close BAA gaps with Stripe, GitHub, Cloudflare, Sumo Logic, and PagerDuty or migrate to covered alternatives.
Q4 2026	Expand NIST CSF coverage to Identify, Detect, Respond, and Recover functions with mapped controls.
Q4 2026	Implement automated evidence collection for AWS, Auth0, and endpoint security controls.
Q1 2027	Conduct independent penetration test and third-party risk reassessment.
Q1 2027	Prepare HIPAA security risk analysis attestation and management reporting dashboard.

Portfolio conclusion

Helix Health has established a defensible GRC baseline: risks are quantified, policies are active, and vendors are tiered. The priority now is evidence-backed execution, closing BAA gaps, and expanding the control framework beyond the Protect function.